

Ihr Datenschutz-Bericht

<https://www.heise.de/>

RISIKO HOCH

Bewertung 100/100

Erhebliche DSGVO-Risiken. Sofortiger Handlungsbedarf.

Geprüft am 21.08.2026 12:27 UTC

Bericht-Nr. DSF-1069FD0CD01C

Ueberblick

9

Geprüft

3

In Ordnung

2

Hinweise

3

Handlungsbedarf

3

Drittanbieter

OK

HTTPS-Verschlüsselung

OK

SSL-Zertifikat

Handlungsbedarf

Datenschutzerklärung

OK

Impressum

Info

Cookie-Consent

Handlungsbedarf

Drittanbieter-Dienste

Handlungsbedarf

Tracking & Analytics

Hinweis

Security Headers

Hinweis

Kontaktformulare

Ergebnisse im Detail

OK HTTPS-Verschlüsselung

HTTPS aktiv. HSTS aktiv (max-age vorhanden).

Art. 32 DSGVO (Sicherheit der Verarbeitung)

OK SSL-Zertifikat

Zertifikat gueltig (55 Tage). TLSv1.3. Aussteller: Let's Encrypt.

– Protokoll: TLSv1.3

– Gueltig noch 55 Tage (Aussteller: Let's Encrypt)

Art. 32 DSGVO

Handlungsbedarf Datenschutzerklärung

Seite unter <https://www.heise.de/datenschutz> nicht abrufbar oder zu kurz.

Empfehlung: Datenschutzerklärung muss mindestens alle Pflichtangaben enthalten.

Art. 13/14 DSGVO

OK Impressum

Impressum vorhanden. Vollstaendigkeit: 83%.

– Fehlend: vertretung

Empfehlung: Fehlende Pflichtangaben ergaenzen.

DDG § 5

Info Cookie-Consent

Kein Consent-System erkannt. Keine offensichtlichen Tracker gefunden.

Empfehlung: Falls zukuenftig Tracking eingesetzt wird, Consent-Tool einrichten.

Handlungsbedarf Drittanbieter-Dienste

3 externe Dienste erkannt, davon 3 mit hohem Risiko.

- Google Ads (advertising, US, Risiko: hoch)
- Meta/Facebook (advertising, US, Risiko: hoch)
- LinkedIn (advertising, US, Risiko: hoch)

Empfehlung: Google Fonts lokal einbinden. Fuer US-Dienste AVV und SCCs pruefen.

Art. 44ff. DSGVO, Schrems II

Handlungsbedarf Tracking & Analytics

3 Tracking-Dienste erkannt.

- Google Ads (US)
- Meta/Facebook (US)
- LinkedIn (US)

Empfehlung: Alle Tracking-Dienste muessen in der Datenschutzerklaerung aufgefuehrt und per Consent-Tool einwilligungspflichtig sein.

Art. 6 Abs. 1 lit. a DSGVO, § 25 TDDDG

Hinweis Security Headers

Security Headers teilweise vorhanden (57%).

- Fehlend: Content-Security-Policy, Referrer-Policy, Permissions-Policy

Empfehlung: Fehlende Security Headers im Webserver konfigurieren.

Art. 32 DSGVO (technische Massnahmen)

Hinweis Kontaktformulare

4 Formular(e) gefunden, 1 Auffaelligkeit(en).

- Formular 3 mit personenbezogenen Feldern (email): kein Datenschutzhinweis

Empfehlung: Bei jedem Formular mit personenbezogenen Daten: Datenschutzhinweis anbringen.

Art. 13 DSGVO

Erkannte Drittanbieter

Dienst	Zweck	Land	Risiko
Google Ads	advertising	US	hoch
Meta/Facebook	advertising	US	hoch
LinkedIn	advertising	US	hoch

Was zu tun ist

Prioritaet	Bereich	Massnahme
HOCH	Datenschutzerklaerung	Datenschutzerklaerung muss mindestens alle Pflichtangaben enthalten.
HOCH	Tracking & Analytics	Alle Tracking-Dienste muessen in der Datenschutzerklaerung aufgefuehrt und per Consent-Tool einwilligungspflichtig sein.
MITTEL	Drittanbieter-Dienste	Google Fonts lokal einbinden. Fuer US-Dienste AVV und SCCs pruefen.
MITTEL	Security Headers	Fehlende Security Headers im Webserver konfigurieren.

NIEDRIG

Kontaktformulare

Bei jedem Formular mit personenbezogenen Daten:
Datenschutzhinweis und Link zur DSE direkt am Formular
anbringen.

Diese Punkte sind kein Grund zur Sorge. Wie Sie sie beheben, lesen Sie auf der naechsten Seite.

Ihre Anleitung, Schritt fuer Schritt

Auf den folgenden Seiten steht fuer jeden offenen Punkt genau, was zu tun ist. In klarem Deutsch, in der richtigen Reihenfolge. Arbeiten Sie die Punkte von oben nach unten ab. Ganz unten steht jeweils, woran Sie erkennen, dass es erledigt ist.

1. Datenschutzerklaerung vervollstaendigen (Handlungsbedarf)

- 1** Erstellen Sie eine vollstaendige Datenschutzerklaerung. Seriose, kostenlose Generatoren: e-recht24.de oder datenschutz-generator.de. Beantworten Sie die Fragen zu Ihrer Website ehrlich.
- 2** Stellen Sie sicher, dass diese Pflichtangaben enthalten sind: Name und Kontakt des Verantwortlichen, Zweck und Rechtsgrundlage, Speicherdauer, Ihre Rechte (Auskunft, Loeschung, Widerspruch), zustaeundige Aufsichtsbehoerde und alle eingesetzten Dienste (z. B. Google, Meta) samt Uebermittlung in die USA.
- 3** Veroeffentlichen Sie die Erklaerung als eigene Seite und verlinken Sie sie im Fussbereich JEDER Seite.

Tipp: WordPress: Seite „Datenschutz“ anlegen, Text einfuegen, im Footer-Widget verlinken.

Fertig, wenn: Die Seite ihre-domain.de/datenschutz existiert und enthaelt alle genannten Punkte.

2. Externe Dienste entschaeufen (Google Fonts & Co.) (Handlungsbedarf)

- 1** Google Fonts lokal einbinden: Schrift bei gwfh.mranftl.com herunterladen, Dateien auf Ihren Server legen, per @font-face einbinden und den Verweis auf fonts.googleapis.com entfernen.
- 2** Fuer jeden US-Dienst (Google, Meta, LinkedIn) pruefen, ob Sie ihn wirklich brauchen. Wenn ja: Auftragsverarbeitungsvertrag (AVV) abschliessen und die Uebermittlung auf die EU-Standardvertragsklauseln (SCC) stuetzen.
- 3** Diese Dienste erst NACH Einwilligung des Besuchers laden (siehe naechster Punkt).

Tipp: WordPress: Das Plugin „OMGF“ bindet Google Fonts automatisch lokal ein.

Fertig, wenn: Im Browser mit F12 → Netzwerk erscheint beim Neuladen keine Anfrage mehr an fonts.googleapis.com.

3. Tracking nur mit Einwilligung (Handlungsbedarf)

- 1** Ein Einwilligungs-Tool (Consent-Banner) installieren: z. B. Borlabs Cookie, Complianz, Cookiebot oder Usercentrics.
- 2** So einstellen, dass ALLE nicht-notwendigen Dienste (Google Ads, Meta Pixel, LinkedIn) erst laden, wenn der Besucher aktiv zustimmt. Vorangekreuzte Haekchen sind nicht erlaubt.
- 3** Jeden Dienst in die Datenschutzerklaerung eintragen – mit Zweck, Rechtsgrundlage (Einwilligung, Art. 6 Abs. 1 lit. a) und Hinweis auf die USA-Uebermittlung.

Tipp: Testen Sie im privaten Browserfenster: Vor dem Klick auf „Zustimmen“ darf kein Tracker laden.

Fertig, wenn: Ohne Einwilligung werden keine Tracker geladen, und alle Dienste stehen in der Datenschutzerklaerung.

4. Sicherheits-Header ergaenzen (Hinweis)

- 1** Die fehlenden Header in der Server-Konfiguration ergaenzen. Wichtig: Content-Security-Policy, Referrer-Policy (Empfehlung: strict-origin-when-cross-origin), Permissions-Policy.
- 2** Apache: in die .htaccess eintragen. nginx: per add_header im server-Block. Im Zweifel Ihren Hoster fragen.

Tipp: WordPress: Plugins wie „Really Simple Security“ setzen viele Header automatisch.

Fertig, wenn: Auf securityheaders.com erreicht Ihre Seite mindestens Note B.

5. Formulare mit Datenschutzhinweis versehen (Hinweis)

- 1** Bei jedem Formular mit personenbezogenen Feldern (Name, E-Mail) einen kurzen Datenschutzhinweis direkt darunter einfüegen – mit Link zur Datenschutzerklärung.
- 2** Formulierung z. B.: „Mit dem Absenden stimmen Sie der Verarbeitung Ihrer Daten gemaess unserer Datenschutzerklärung zu.“

Tipp: Empfehlenswert ist zusaetzlich eine Pflicht-Checkbox zur Einwilligung.

Fertig, wenn: Jedes Formular zeigt sichtbar einen Datenschutzhinweis mit Link.

Keine Zeit oder Lust auf das Technische?

Sie muessen das nicht selbst machen. Schicken Sie mir diesen Bericht, und ich setze die Punkte fuer Sie um. Sie kuemmern sich weiter um Ihr Geschaef.

Umsetzung anfragen →

Noch Fragen? Schreiben Sie mir einfach: sf.foodzeit@googlemail.com

Dieser Bericht wurde automatisch vom DSGVO-Checker (DSF Consulting) erstellt und stellt keine Rechtsberatung dar. Die Analyse ist eine technische Momentaufnahme der Website. Fuer eine rechtssichere Bewertung ziehen Sie bitte eine Datenschutzbeauftragte oder einen Anwalt hinzu.